



ZeroOTP for Keycloak

Session-bound Hardware TOTP with WebAuthn PRF

A Keycloak Authentication SPI plugin that keeps RFC 6238 TOTP compatibility while adding verifier-bound, session-bound cryptographic protection.

PRF + session proof



Executive summary

What changes when ZeroOTP becomes a Keycloak authenticator

ZeroOTP for Keycloak is an Authentication SPI plugin, not a standalone demo page.
It keeps standard RFC 6238 TOTP as an internal compatibility component.
The user never reads or types the six-digit code: the browser generates it after PRF unlock.
Version 1.1.0 adds a server-generated 256-bit challenge and a session-bound HMAC proof.
The security story is no longer “better TOTP”; it is a verifier-bound, session-bound cryptographic authentication protocol.

Headline

TOTP remains inside.
The authenticator output is now
bound to the Keycloak session.

Search terms: NIST phishing resistance



Why ordinary OTP is not enough

The problem is transferability, not the number of digits

Traditional TOTP

A valid code is accepted because it matches the shared secret and current time window.

Phishing/relay weakness

If an attacker obtains the code while it is valid, the code does not know which session it came from.

NIST wording to search

Multi-Factor OTP
authenticator output
phishing-resistant
verifier name binding

NIST: OTP authentication is not phishing-resistant when the output is transferable and not bound to the verifier/session.



One ZeroOTP tree, now with a Keycloak branch

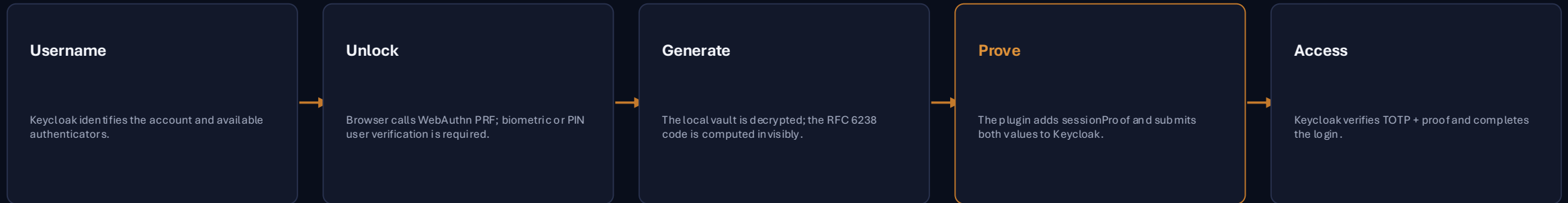
The plugin extends the browser PRF model with verifier-side state





What the user experiences

Passwordless-style interaction, TOTP-compatible backend logic

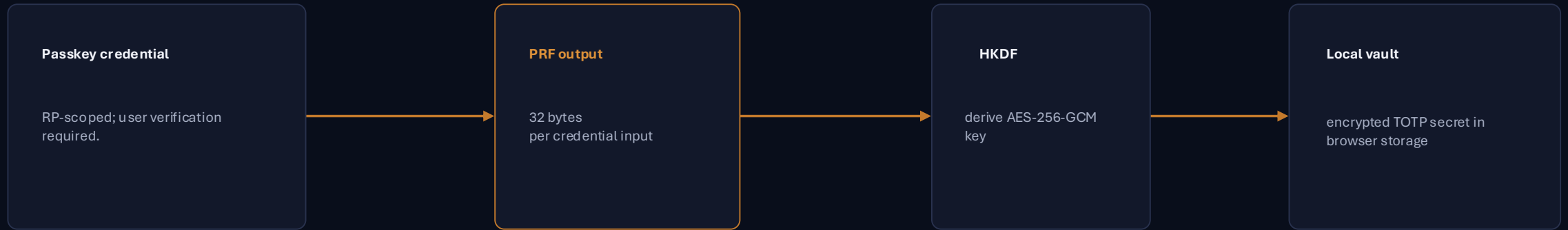


There is still a six-digit TOTP — but the user does not handle it, and Keycloak will not accept it without the matching session proof.



Role of WebAuthn PRF

PRF protects the secret; it is not the whole protocol



PRF answers the question: “May this browser recover the local TOTP secret using the enrolled WebAuthn credential?”

Search terms: WebAuthn PRF extension · hmac-secret · credential-associated pseudorandom function



The added cryptographic session component

The reason the plugin changes the security classification

Verifier-generated challenge

256-bit random value
stored in Keycloak AuthenticationSession
used as WebAuthn get() challenge
single-use: consumed after the attempt

sessionProof

```
HMAC-SHA-256(  
  TOTP-secret,  
  "zerotp-session-v1" || challenge || TOTP  
)
```

Keycloak accepts the login only when the TOTP and the proof both match the same authentication session.

Business translation: a stolen six-digit code is no longer a credential.



Protocol flow, in one slide

TOTP inside; cryptographic binding outside





NIST terminology, translated

Words a reviewer can search and verify

Authenticator output

Not just the six digits: Keycloak requires TOTP + sessionProof.

Verifier name binding

WebAuthn credential use is scoped to the RP / legitimate origin.

Replay resistance

A proof from session A does not verify in session B.

Authentication intent

User verification is required before PRF unlock.

Phishing resistance

The protocol prevents ordinary OTP capture and cross-session relay.

Suggested search pattern: “NIST SP 800-63B verifier name binding authenticator output phishing resistant”.



Security classification

A careful wording: strong, searchable, not overstated

Do not describe it as only...

“A Multi-Factor OTP Device that became phishing-resistant because the user cannot see the code.”

That under-describes the protocol and conflicts with NIST wording on conventional OTP authentication.

Preferred description

“A session-bound cryptographic authentication protocol that retains RFC 6238 TOTP as an internal compatibility component.”

AAL2-oriented design; AAL3 requires additional evidence about key exportability, device binding, validation, and policy controls.

NIST phrases: cryptographic authentication protocol - verifier name binding - phishing resistance



Threats this design is meant to block

A concise map for security and risk teams

OTP capture

Six digits alone are rejected.

Cross-session replay

Proof from session A fails in session B.

Fake origin

WebAuthn RP scoping blocks credential use by the impostor origin.

Local secret theft

The browser copy is AES-GCM encrypted using PRF-derived keying material.

Full endpoint compromise

Out of scope: malware in the legitimate origin can act as the user.

Server secret compromise

Residual shared-secret risk inherited from RFC 6238.



Keycloak integration

A native login-flow component, not an external helper

Provider

Authentication SPI
Required Action for enrollment
Custom login theme
Credential model

Flow

Username Form
↓
Authentication Methods
├ Password
└ Hardware TOTP

Artifact

target/zerotp-hardware-totp-1.1.0.jar

Docker-ready build
Keycloak 26.x target
No weaker non-PRF fallback

Admin Console: Authentication → Flows → Browser → HardwareTOTP



Microsoft Entra view

Technical phishing resistance is not the same as a built-in Entra method

What Microsoft recognizes directly

Windows Hello for Business / platform credential
FIDO2 security key / passkey
Certificate-based authentication
Microsoft Authenticator passkeys

How ZeroOTP can fit

As a Keycloak method for applications federated behind Keycloak
As federated MFA in Entra policy terms when the IdP asserts MFA
Not automatically a built-in Entra “Phishing-resistant MFA strength” method

Use Microsoft language carefully: map the protocol properties, then separately map what Conditional Access can enforce.



Why it matters

Security language that a buyer, auditor, and engineer can all verify

Market message

Invisible OTP UX with strong cryptographic binding — no copy/paste ritual, no OTP relay as a sufficient attack.

Security message

PRF protects secret release; sessionProof binds the output to the verifier challenge and session.

Compliance message

Use NIST terms directly: authenticator output, verifier-name binding, replay resistance, phishing resistance.

The searchable story: "session-bound cryptographic authentication protocol using RFC 6238 TOTP internally"



Thank you

ZeroOTP for Keycloak · Session-bound Hardware TOTP

Repository root: ZeroOTP

Plugin directory: KeyCloakPlugin/

Build artifact: target/zerotp-hardware-totp-1.1.0.jar

Read: README.md, KeyCloakPlugin/README.md, SECURITY-ARCHITECTURE.md, SECURITY-SESSION-BINDING.md

Search: NIST SP 800-63B phishing resistance verifier name binding authenticator output



ZeroOTP
for Keycloak